

RELAZIONE FINALE

Analisi dinamica del Link 2 – ANY.RUN

Esercizio 5

Lana Mazibrada

Valutazione del comportamento osservato, verifica degli indicatori di phishing e malware e decisione di remediation.

VERDETTO: PHISHING NON CONFERMATO — MALWARE NON DIMOSTRATO

1. Obiettivo e approccio dell'analisi

Ho analizzato il secondo collegamento partendo dall'esecuzione nella sandbox ANY.RUN e ho poi approfondito gli elementi che nella prima analisi lasciavano più dubbi. Ho controllato la pagina raggiunta, i processi, i file, il registro, le richieste DNS, le connessioni di rete e i dati del browser. In seguito mi sono concentrata sul dominio **click.convertkit-mail2.com**, sulla sua comunicazione HTTPS e sulla destinazione contenuta nell'URL.

Per avere anche un confronto esterno ho verificato la URL con VirusTotal e Kaspersky OpenTIP e ho controllato il contesto dell'infrastruttura. Ho inoltre provato a ottenere un accesso più completo ad ANY.RUN, così da poter verificare meglio la parte HTTP/redirect.

Fase	Cosa ho verificato	Risultato
Triage	Pagina, processi, file, registro e rete	Nessun processo classificato malicious o suspicious.
URL	Struttura e parte finale codificata	La stringa Base64 porta a www.instagram.com/aussienurserecruiters .
Rete	DNS, TCP/443 e traffico	Chrome NetworkService ha realmente contattato il dominio iniziale.
Browser	Process Graph e attività locale	Attività principalmente riconducibile a Chrome.
Controlli esterni	VirusTotal, Kaspersky e infrastruttura	Segnali misti, ma senza conferma di phishing.
Remediation	Quarantena, blacklist, falso positivo/negativo	Scelta prudenziale: non classificare il link come malware.

The screenshot shows the Wireshark interface with the 'Connections' tab selected. The table below represents the data visible in the main pane.

Timeshift	Protocol	Rep	PID	Process name	CN	IP	Port	Domain	ASN	Traffic
6227 ms	TCP	?	6840	chrome.exe		3.141.222.179	443	click.convertkit-mail2.com	AMAZON-02	↑ 1 Kb ↓ 6 Kb

Figura 1 – Connessione osservata verso click.convertkit-mail2.com.

2. Identificazione del collegamento

Il collegamento analizzato è:

<https://click.convertkit-mail2.com/wvuqovqrrwagh50ndddc7hnxdlxxu8/48hvhehr87opx8ux/d3d3Lmluc3JhZ3Jhbs5jb20vYXVzc2llbnVyc2VyY3J1aXRlcnm>

L'ultimo segmento è codificato in Base64. La decodifica restituisce: **www.instagram.com/aussienurserecruiters**. Quindi la destinazione Instagram è effettivamente incorporata nella URL.

La struttura è compatibile con un sistema di tracking o redirect: c'è un dominio intermedio, il percorso contiene identificativi e la destinazione è codificata. Non ho però considerato dimostrato un preciso codice HTTP di redirect, perché nella schermata del Network Stream il traffico è TLS cifrato.

La schermata mostra il dominio iniziale associato alla connessione di Chrome e permette di collegare l'URL osservata all'attività di rete effettiva.

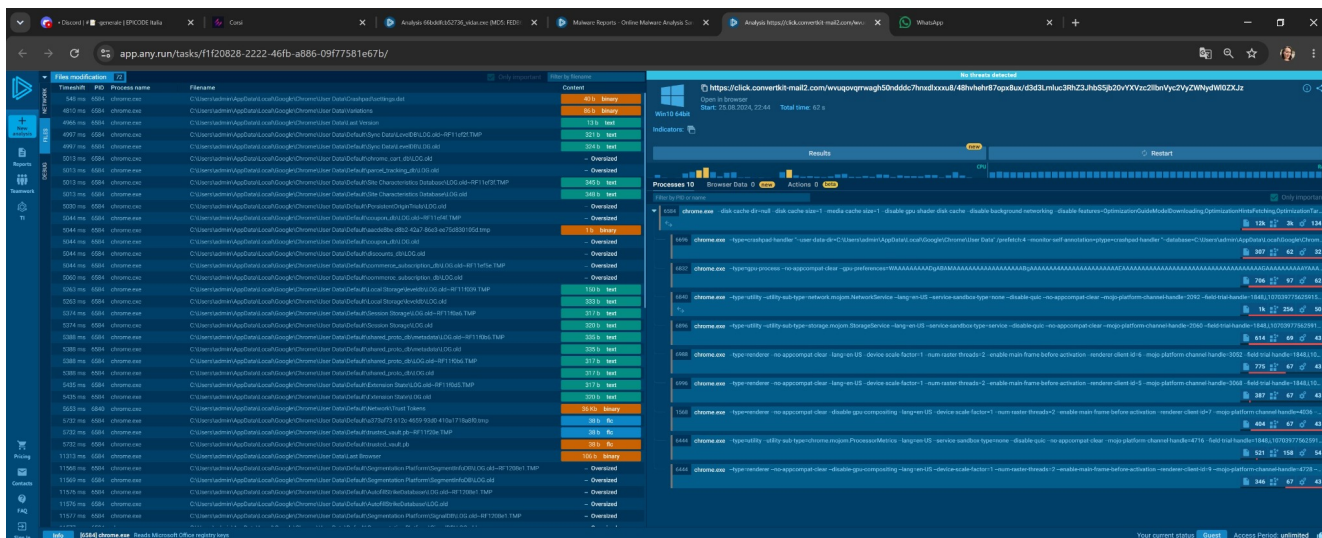


Figura 2 – Panoramica della task ANY.RUN con attività di rete e processi.

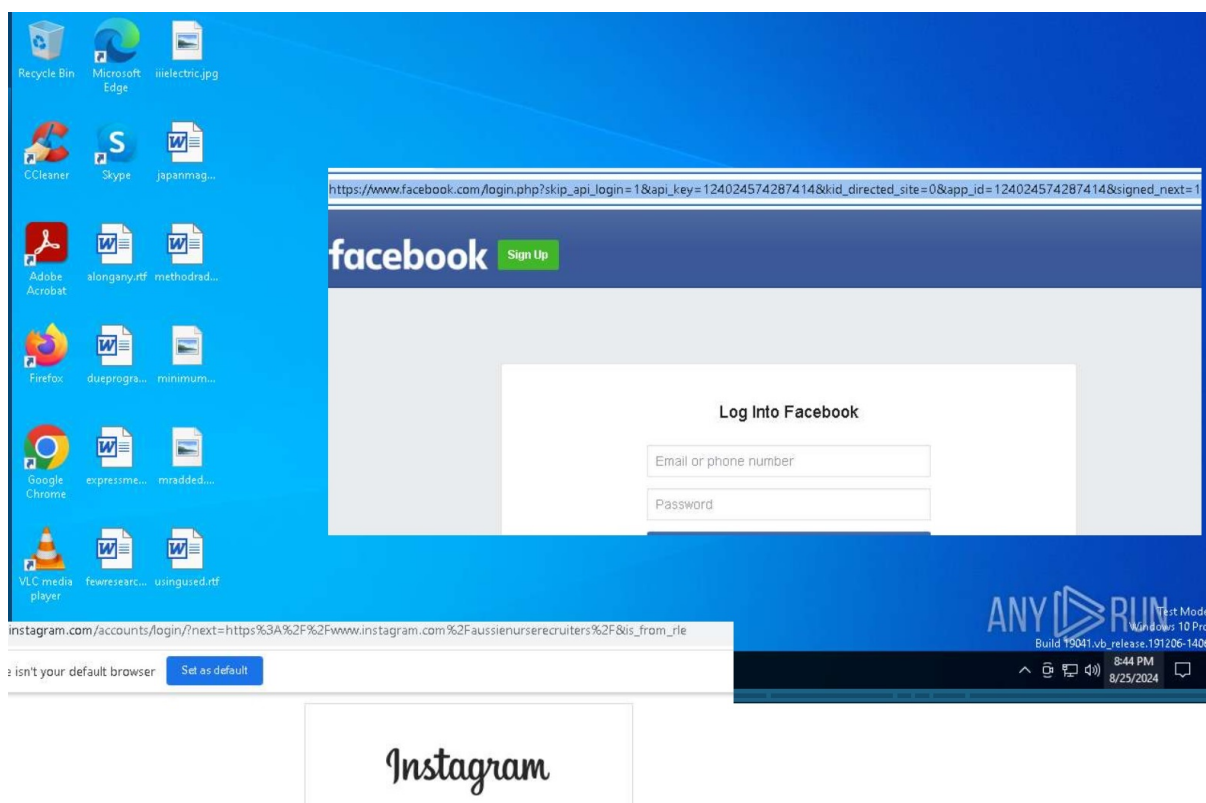


Figura 3 – Pagina di login Facebook e riferimento alla destinazione Instagram.

3. Prima analisi in ANY.RUN

Nella prima analisi Chrome era il componente centrale dell'esecuzione. La vista generale mostrava attività del browser, modifiche al profilo Chrome e collegamenti verso servizi social e servizi di sistema.

I contatori riportati dalla task erano **3 HTTP Requests**, **48 Connections**, **33 DNS Requests** e **0 Network Threats**. La navigazione mostrava Facebook e Instagram sui rispettivi domini ufficiali.

La sezione Browser Data non mostrava dati utili. Questo non permette di dire che un eventuale trattamento di credenziali fosse impossibile; significa semplicemente che, nell'esecuzione osservata, non è comparsa un'evidenza concreta di furto di credenziali.

Il punto che ho deciso di approfondire è stato quindi il passaggio iniziale attraverso `click.convertkit-mail2.com`: era necessario capire se il dominio fosse stato realmente contattato e quale ruolo avesse nella navigazione.

4. Process Graph e processi Chrome

Nel riesame ho controllato il Process Graph perché alcuni indicatori automatici di ANY.RUN, letti senza contesto, potevano sembrare più preoccupanti di quanto fossero. I processi visibili erano numerosi chrome.exe con ruoli tipici del browser: crashpad-handler, gpu-process, NetworkService, StorageService e renderer.

Elemento	Evidenza	Valutazione
Processo principale	chrome.exe, PID 6584, avviato da explorer.exe	Compatibile con l'apertura normale del browser.
NetworkService	chrome.exe, PID 6840	Processo di rete di Chrome; è quello associato alla connessione iniziale.
Renderer	Più processi chrome.exe	Normale architettura multiprocesso.
GPU / Crashpad / Storage	Processi figli con ruoli specifici	Non sono, da soli, indicatori di malware.
Catena di esecuzione	Non compare Chrome → PowerShell/cmd → eseguibile sconosciuto	Nessuna catena di payload separato osservata.

Il Text Report quantifica **139 processi totali, 10 monitorati, 0 malicious e 0 suspicious**. Anche l'indicatore "Application launched itself" va quindi letto nel contesto del browser: non emerge un processo estraneo che dimostri l'auto-esecuzione di un malware.

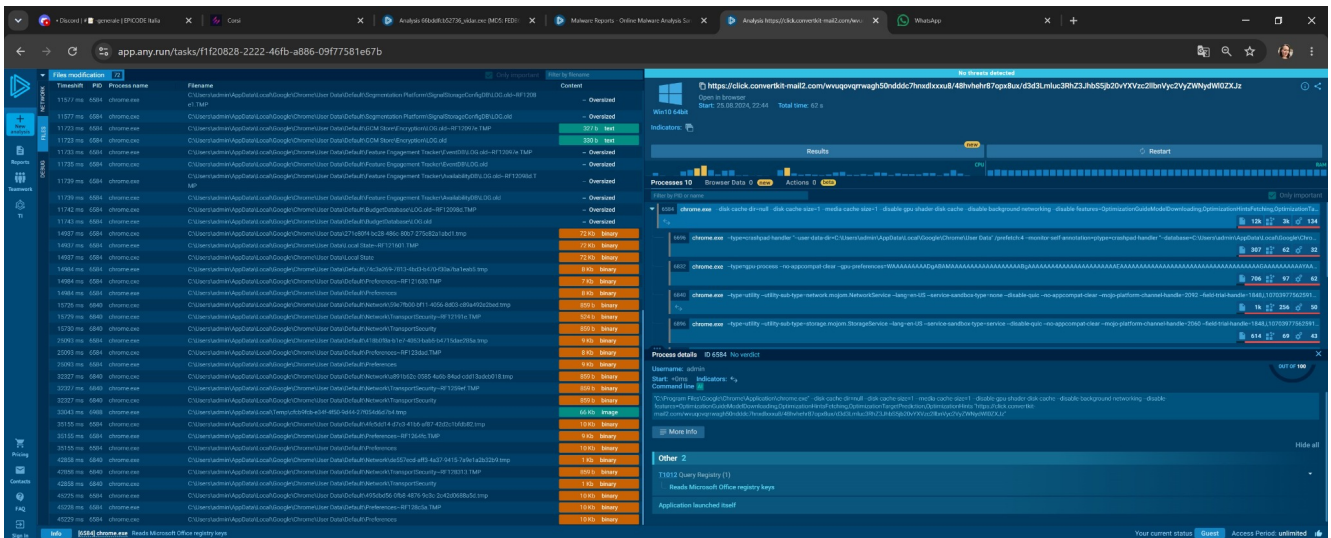


Figura 4 – Vista dettagliata della task con eventi di rete e attività osservata.

5. File e registro

La task mostra numerosi artefatti creati o modificati durante la navigazione. Il Text Report indica **0 file eseguibili**, 30 elementi classificati dalla piattaforma come “suspicious files”, 18 file di testo e 2 elementi di tipo sconosciuto.

Ho verificato i dettagli perché il numero “30 suspicious files” può essere facilmente frainteso. Gli elementi elencati sono principalmente artefatti del profilo Chrome: database, LOG/LOG.old, Preferences, Local State, Crashpad, Variations, Session Storage, Network e altri file legati alla normale attività del browser.

Area	Dato	Lettura
File eseguibili	0	Non risulta la creazione di un eseguibile malevolo.
Artefatti Chrome	Numerosi	Cache, database, sessioni e configurazione del browser.
Registro	4.567 eventi	4.549 letture, 18 scritture, 0 cancellazioni.
Scritture	18	Le evidenze disponibili le collegano a Chrome/Google Update.
“Reads Microsoft Office registry keys”	Evento osservato	Non è sufficiente per parlare di persistenza o malware.

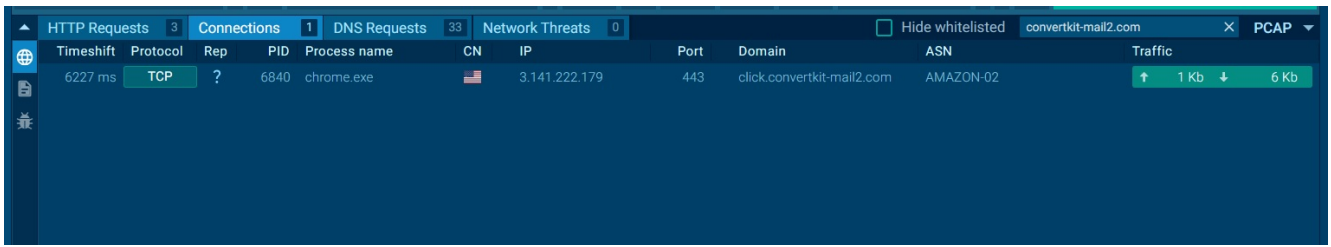


Figura 5 – Dettaglio della connessione TCP/443 verso il dominio iniziale.

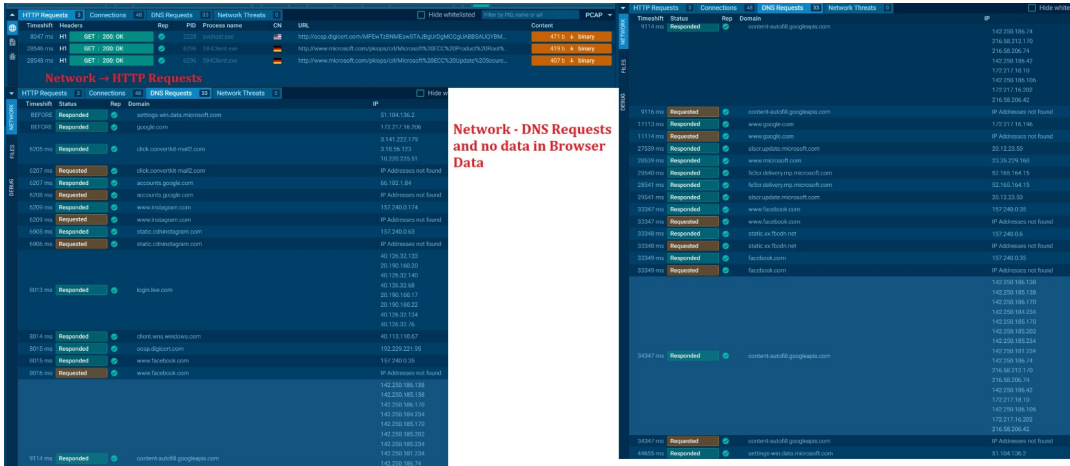


Figura 6 – Network Stream e connessioni osservate nella task.

6. Ricostruzione della comunicazione iniziale

Il passaggio più importante del riesame è stato verificare se click.convertkit-mail2.com fosse soltanto una parte della URL oppure un host realmente contattato. La connessione mostra **chrome.exe PID 6840 → TCP → 3.141.222.179:443 → click.convertkit-mail2.com**. ANY.RUN registra circa **1 KB in uscita e 6 KB in ingresso**.

La vista Network Stream mostra un flusso RAW bidirezionale tra 3.141.222.179:443 e la porta effimera della VM. Il contenuto è TLS cifrato. Posso quindi dimostrare la comunicazione HTTPS, ma non leggere da questa schermata gli header HTTP.

Per lo stesso motivo non considero verificato, per questa specifica task, un codice 301, 302, 307 o 308. Il fatto che altri campioni della stessa infrastruttura possano usare 302 non sostituisce la verifica di questa esecuzione.

HTTP Requests		3		Connections		48		DNS Requests		2		Network Threats		0		☐ Hide whitelisted		convertkit-mail2.com		✕		PCAP	
Timeshift		Status		Rep		Domain								IP									
6205 ms		Responded		✔		click.convertkit-mail2.com								3.141.222.179									
														3.18.56.123									
														18.220.225.51									
6207 ms		Requested		✔		click.convertkit-mail2.com								IP Addresses not found									

Figura 7 – Risoluzione DNS osservata per click.convertkit-mail2.com.

7. Risoluzione DNS

La risposta DNS osservata per click.convertkit-mail2.com restituisce tre indirizzi IPv4: **3.141.222.179**, **3.18.56.123** e **18.220.225.51**.

La seconda riga mostrata nella schermata è “Requested / IP Addresses not found” e non l’ho interpretata come una seconda risoluzione riuscita. La parte utile è la riga “Responded” con i tre IP.

Mettendo insieme URL, DNS e connessione si ottiene una catena minima osservata: **URL iniziale** → **DNS** **click.convertkit-mail2.com** → **3.141.222.179** → **TCP/443** → **TLS** → **Chrome**.

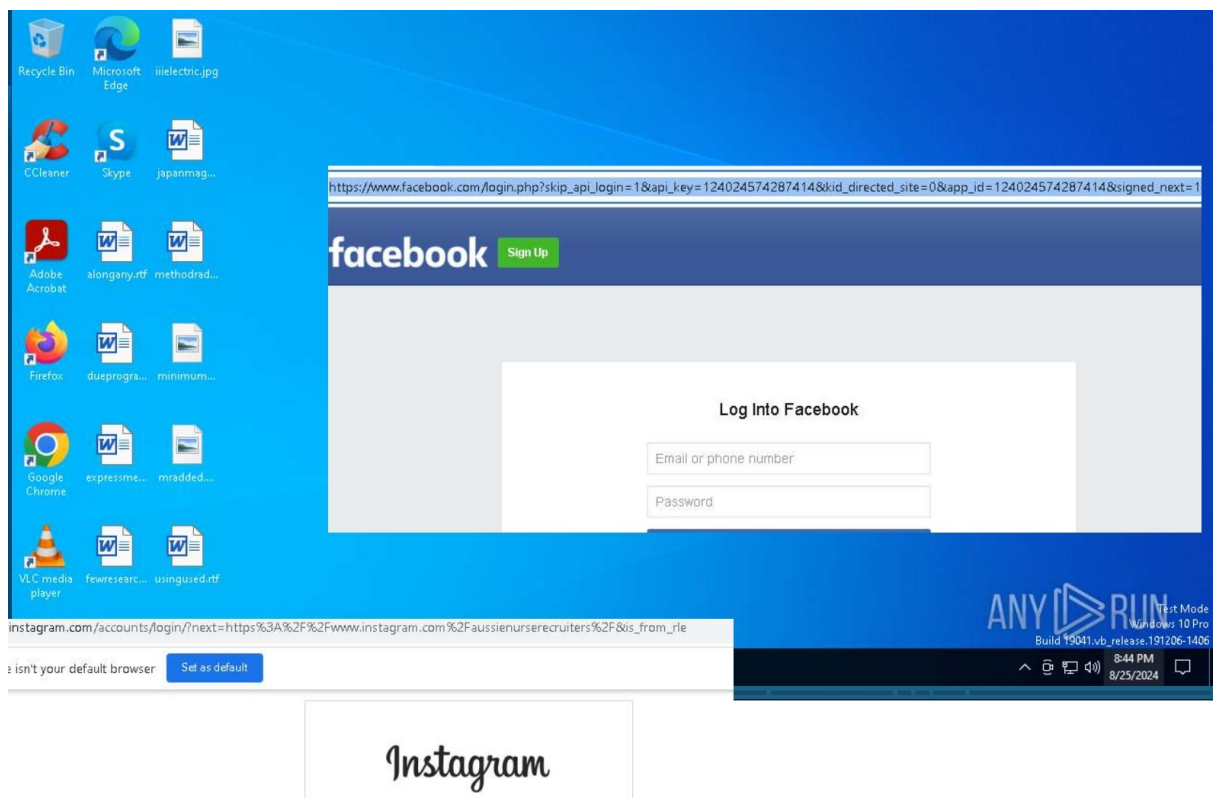


Figura 8 – Schermata osservata durante la navigazione verso Facebook/Instagram.

8. Navigazione e possibile phishing

La navigazione osservata porta a pagine sui domini ufficiali Facebook e Instagram. Questo è importante perché non è comparso un classico look-alike domain. La destinazione contenuta nell'URL è infatti www.instagram.com/accounts/login/?next=https%3A%2F%2Fwww.instagram.com%2Faussienurse recruiters%2F&is_from_rle.

Indicatore	Osservazione	Valutazione
Dominio iniziale	click.convertkit-mail2.com	È l'elemento che richiede più contesto.
Destinazione Base64	www.instagram.com/aussienurse recruiters	Compatibile con redirect/tracking verso Instagram.
Facebook	www.facebook.com	Dominio ufficiale.
Instagram	www.instagram.com	Dominio ufficiale.
Login	Pagina di accesso visibile	Merita cautela, ma non dimostra phishing.
Credenziali	Nessun inserimento/invio osservato	Nessun furto di credenziali dimostrato.

La presenza di una schermata di login, da sola, non basta per classificare il link come phishing. Per arrivare a quella conclusione servirebbe un elemento concreto come un dominio contraffatto, un form ospitato altrove o l'invio delle credenziali a un server estraneo. Questi elementi non sono stati osservati.

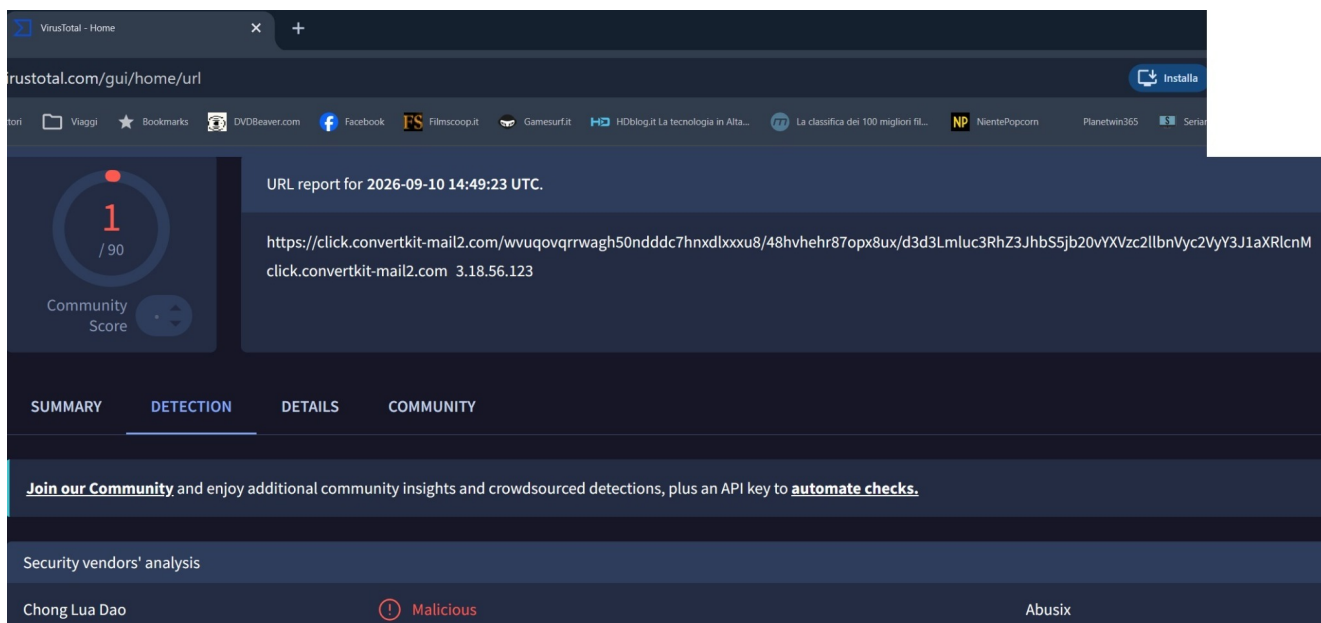


Figura 9 – Risultato VirusTotal con un solo rilevamento su 90.

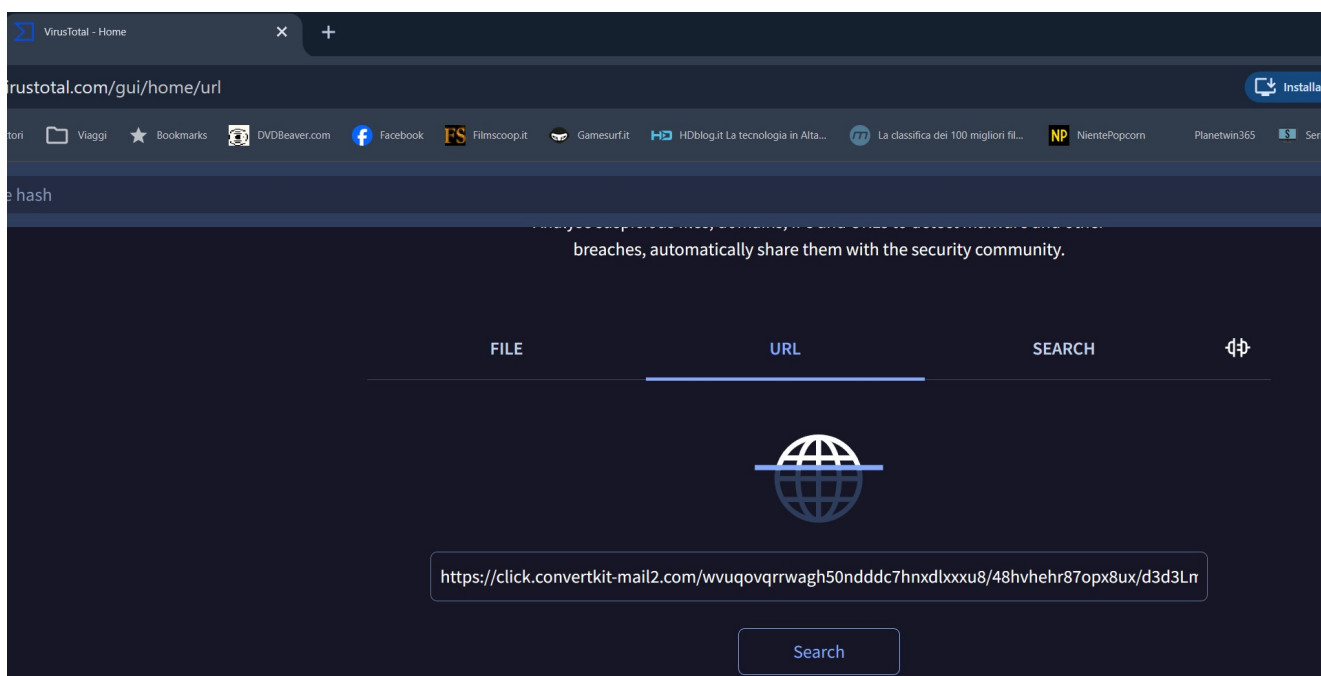


Figura 10 – Verifica della URL tramite la ricerca di VirusTotal.

9. VirusTotal

Ho controllato la URL completa con VirusTotal. Il risultato visualizzato è stato **1/90**: un solo motore, indicato come Chong Lua Dao / Abusix, ha classificato la URL come “Malicious”.

Ho considerato questo dato un segnale da non ignorare, ma non sufficiente da solo per ribaltare il quadro. La grande maggioranza dei motori non ha prodotto un rilevamento e, nella stessa analisi, ANY.RUN non ha segnalato minacce di rete.

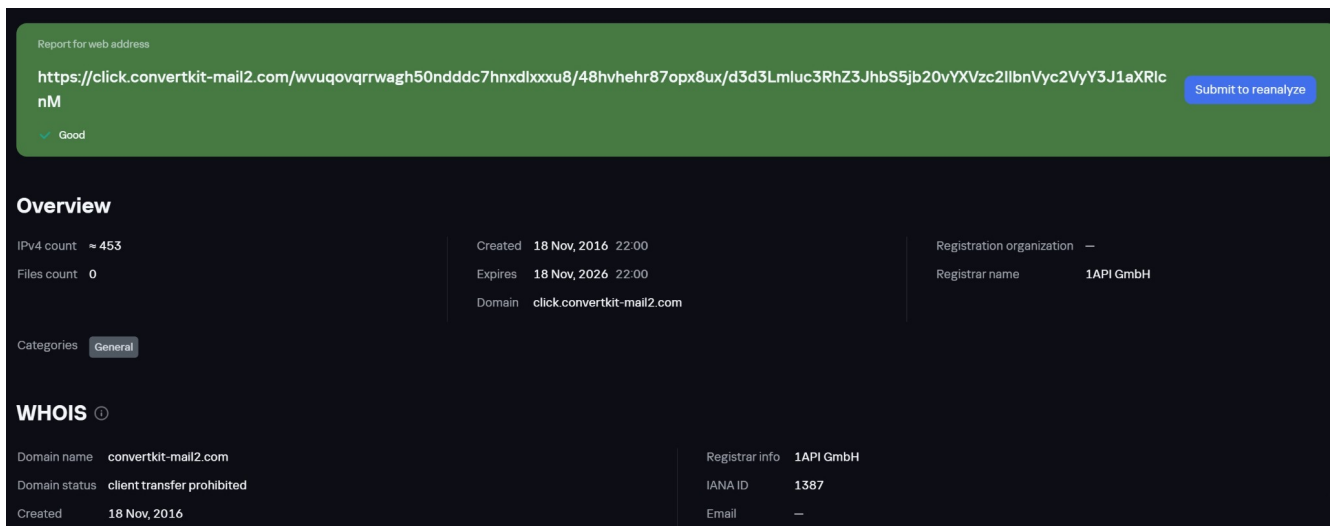


Figura 11 – Verifica della web address tramite Kaspersky OpenTIP.

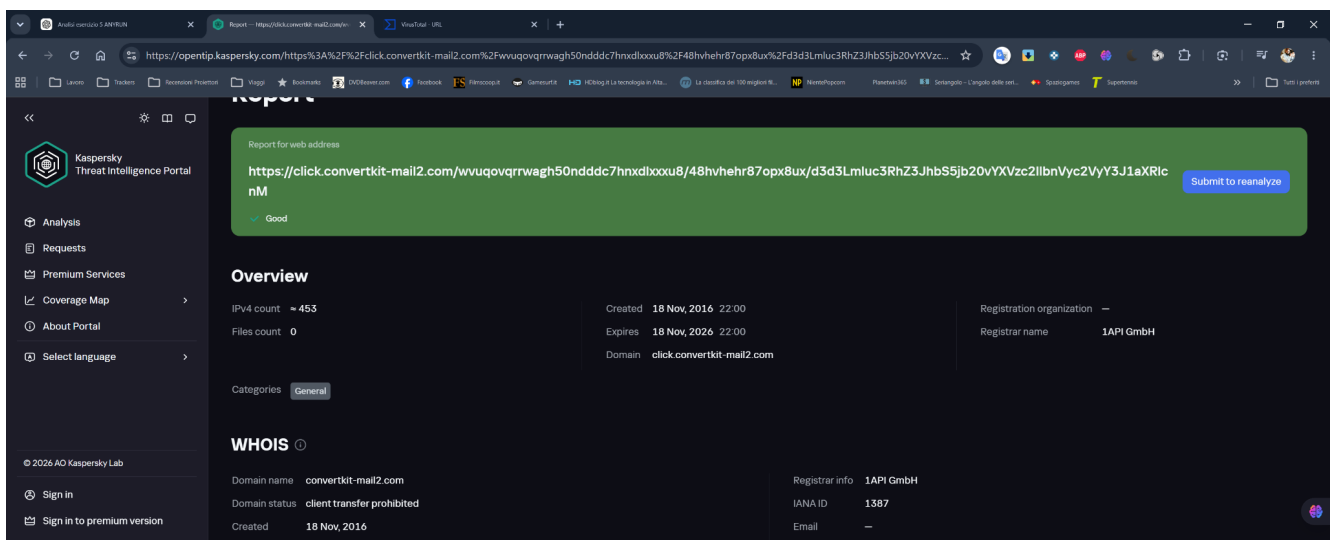


Figura 12 – Contesto del dominio e informazioni infrastrutturali visualizzate durante i controlli esterni.

10. Kaspersky OpenTIP

Come controllo indipendente ho sottoposto la web address completa a Kaspersky Threat Intelligence Portal. Il risultato mostrato è **Good**. Non sono presenti nomi di rilevamento e non risultano dati aggiuntivi nella sezione di analisi dinamica.

Anche in questo caso non considero “Good” una certificazione assoluta del link. È però un secondo controllo esterno che, sulla URL analizzata, non ha prodotto una classificazione malevola.

11. Contesto del dominio e dell'infrastruttura

Ho controllato anche il dominio e l'IP per capire se l'anomalia potesse essere legata a un'infrastruttura appena creata o palesemente malevola. I dati pubblici consultati mostrano un dominio presente da anni e associato ad Amazon / AS16509. Gli stessi tre IP compaiono nella risposta DNS osservata nella sandbox.

Elemento	Dato	Come l'ho considerato
Dominio	click.convertkit-mail2.com	Infrastruttura reale, non un dominio appena apparso.
IPv4	3.141.222.179 / 3.18.56.123 / 18.220.225.51	Coincidono con la risposta DNS della task.
ASN	AS16509 / AMAZON-02	Hosting cloud; non prova né legittimità né malevolenza.
Storia pubblica	Presenza pluriennale	Riduce l'ipotesi di dominio appena creato.
AbuseIPDB sull'IP	3 segnalazioni; confidence 3%	Esiste una storia di abuso, ma il dato non prova questo campione.

L'IP 3.141.222.179 presenta alcune segnalazioni storiche relative a phishing/spam. Questo aumenta la cautela, ma non consente di concludere che la specifica URL sia un phishing: un'infrastruttura condivisa può essere usata in campagne diverse.

12. Tentativo di ottenere un accesso più completo ad ANY.RUN

Durante il riesame ho provato a ottenere un accesso personale ad ANY.RUN perché sarebbe stato utile poter vedere più nel dettaglio il livello applicativo del traffico HTTPS, il PCAP e la catena completa di redirect.

La risposta ricevuta è stata negativa: la richiesta non è stata accettata perché, secondo la loro valutazione, non risultavano soddisfatti i criteri per un account personale gratuito. La risposta specificava che i criteri non vengono pubblicati e suggeriva, per le verifiche malware, servizi alternativi come Kaspersky OpenTIP e VirusTotal.

Non interpreto questo diniego come un giudizio tecnico sul link: riguarda l'accesso alla piattaforma, non la classificazione della URL. Non ho cercato di aggirare il rifiuto con identità false o account multipli.

Dopo il diniego ho quindi utilizzato proprio i due strumenti indicati nella risposta. Questo ha permesso di aggiungere due verifiche indipendenti senza modificare artificialmente le condizioni dell'analisi.

La schermata completa della risposta di ANY.RUN non era tra i materiali immagine disponibili per l'inserimento; il contenuto della risposta è stato comunque riportato qui sulla base del messaggio ricevuto.

13. Quadro finale delle evidenze

Elemento	Risultato
URL iniziale	click.convertkit-mail2.com; il dominio è presente nell'URL ed è stato contattato da Chrome.
Base64	Decodifica → www.instagram.com/aussienurserecruiters.
DNS	3.141.222.179 / 3.18.56.123 / 18.220.225.51.
TCP/443	Chrome NetworkService → 3.141.222.179:443.
TLS	Traffico bidirezionale osservato; contenuto applicativo non leggibile nella vista RAW.
Processi	139 totali / 10 monitorati / 0 malicious / 0 suspicious.
Registro	4.567 eventi; 4.549 read / 18 write / 0 delete.
File	0 eseguibili; attività principalmente collegata al profilo Chrome.
Network Threats	0 nella specifica esecuzione ANY.RUN.
Credenziali	Nessun inserimento o invio osservato nelle evidenze disponibili.
HTTP redirect code	Non verificato dal solo TLS stream.
VirusTotal	1/90: un solo motore ha indicato Malicious.
Kaspersky	Good; nessun nome di rilevamento mostrato.

14. Valutazione del rischio

Alla luce di tutte le verifiche, considero il rischio non nullo ma non sufficientemente dimostrato come malware o phishing operativo. La parte che giustifica prudenza è il dominio intermedio e la presenza di una pagina di autenticazione social. Dall'altra parte, non sono emersi processi malevoli, file eseguibili, una catena di persistenza o un invio di credenziali.

Voce	Valutazione	Motivazione
Malware eseguito	Basso / non dimostrato	0 processi malicious, 0 suspicious e nessun eseguibile osservato.
Persistenza	Non osservata	Nessuna catena di persistenza dimostrata.
Download di payload	Non osservato	Nessun file eseguibile creato.
Phishing	Non confermato	Destinazioni social su domini ufficiali; nessun furto di credenziali osservato.
Tracking / redirect	Probabile	Struttura dell'URL e destinazione codificata sono compatibili.
Reputazione infrastruttura	Mista	Kaspersky favorevole, VirusTotal 1/90, alcune segnalazioni storiche sull'IP.

Non ho attribuito tecniche MITRE ATT&CK; a un malware perché nella task non è stata dimostrata l'esecuzione di una componente malevola. Preferisco descrivere ciò che è stato effettivamente osservato piuttosto che forzare una mappatura.

15. Decisione di remediation

In ottica aziendale, non classificherei il collegamento come malware confermato e non inserirei automaticamente l'intero dominio in una blacklist permanente. La scelta più prudente è trattarlo come link sospetto fino a una validazione del contesto e del mittente.

Azione	Decisione	Motivazione
Quarantena / blocco preventivo	Possibile	Utile se il link non è necessario all'attività aziendale.
Eliminazione definitiva	No	Non c'è una prova conclusiva di malware o phishing operativo.
Blacklist permanente del dominio	No	Il dominio può avere una funzione di tracking/redirect; bloccarlo interamente sarebbe eccessivo sulla base di questa sola analisi.
Falso positivo	Non dichiarato	Gli indicatori non sono sufficienti per dimostrare che tutto sia benigno.
Falso negativo	Non dichiarato	Non ci sono elementi sufficienti per affermare che ANY.RUN abbia mancato un attacco.
Chiedere al vendor	Sì, già tentato	Ho richiesto maggiore visibilità; l'accesso personale è stato rifiutato.
Credenziali	Da non inserire	Il trattamento dei dati inseriti nel login non è stato verificato.

Se il link arrivasse in un contesto aziendale e non fosse indispensabile, lo tratterei come sospetto e ne impedirei l'apertura agli utenti fino alla validazione del mittente e dello scopo. Non userei però questa analisi come motivazione sufficiente per bloccare indiscriminatamente l'intero dominio.

16. Conclusione finale

Ho analizzato il secondo link partendo dalla task ANY.RUN e ho approfondito soprattutto il dominio click.convertkit-mail2.com. La nuova verifica ha dimostrato che il dominio non è soltanto presente nell'URL: Chrome NetworkService ha realmente comunicato con 3.141.222.179 sulla porta 443. Il DNS restituisce tre indirizzi e il Network Stream mostra traffico TLS bidirezionale.

L'analisi dei processi non mostra invece una catena riconducibile a PowerShell, cmd o a un eseguibile sconosciuto. Il Text Report indica 0 processi malicious, 0 suspicious e 0 file eseguibili. Le modifiche locali risultano principalmente legate al profilo Chrome e le scritture di registro osservate sono associate alle componenti Chrome/Google nelle evidenze disponibili.

La URL contiene una destinazione Instagram codificata in Base64 e la navigazione raggiunge Facebook e Instagram sui domini ufficiali. Non è stato osservato l'inserimento o l'invio di credenziali. La struttura è compatibile con un meccanismo di tracking/redirect, ma non è stato possibile verificare dalla schermata TLS il codice HTTP della risposta iniziale né l'intera catena di redirect.

Le verifiche esterne danno un quadro misto: Kaspersky OpenTIP restituisce Good, mentre VirusTotal mostra un solo rilevamento su 90. L'IP presenta inoltre alcune segnalazioni storiche, ma non abbastanza specifiche da dimostrare che questa URL sia un phishing.

La conclusione è quindi che non ho trovato evidenze sufficienti per classificare il collegamento come malware o per confermare un attacco di phishing. Il link non va però considerato automaticamente sicuro: il dominio intermedio, la struttura di tracking/redirect e la presenza di una pagina di autenticazione rendono appropriata una gestione prudentiale.

VERDETTO FINALE: PHISHING NON CONFERMATO — MALWARE NON DIMOSTRATO

17. In sintesi

Il link è stato aperto in un ambiente controllato e ho verificato browser, processi, file, registro e rete. Il passaggio attraverso click.convertkit-mail2.com è reale e porta a una destinazione Instagram, ma nella sandbox non sono comparsi malware, processi sospetti o file eseguibili. Le verifiche esterne sono nel complesso favorevoli, anche se VirusTotal mostra un singolo rilevamento e l'infrastruttura ha qualche segnalazione storica. Per questo non considero il link un malware o un phishing dimostrato, ma lo tratterei comunque con prudenza e non inserirei credenziali attraverso quel collegamento.

Fonti consultate

Fonte	Utilizzo
ANY.RUN – task del Link 2	Process Graph, file activity, registry, rete, pagine raggiunte e indicatori della sandbox.
ANY.RUN – Text Report	Processi, hash, configurazione della sandbox e dettagli di rete/file/registro.
VirusTotal	Controllo reputazionale della URL completa; risultato osservato 1/90.
Kaspersky OpenTIP	Controllo reputazionale della web address; risultato osservato Good.
urlscan.io	Contesto pubblico del dominio e degli indirizzi IP associati.
AbuseIPDB	Verifica della storia di segnalazioni sull'IP osservato.

La relazione è basata sulle evidenze raccolte nella task, sugli screenshot forniti e sui controlli esterni effettuati durante l'analisi.